

(b) Guía metodológica de la Encuesta SOC 2 – ENS – NIS2 (España 2026)

1. Propósito y alcance de la encuesta

Esta encuesta tiene como propósito medir el grado de alineamiento de las organizaciones con las buenas prácticas recogidas en el marco SOC 2 del AICPA y su convergencia con el Esquema Nacional de Seguridad (ENS), la Directiva NIS2 y otras normas de referencia en España y la Unión Europea.

La encuesta está diseñada para:

- Obtener una visión cuantitativa de la **madurez** de ciberseguridad en organizaciones españolas de distintos sectores.
- Identificar brechas específicas en gobernanza, gestión de riesgos, controles técnicos y cultura organizativa.
- Facilitar la elaboración de un Índice Global de Madurez (IGM) y estimar el retorno de la inversión (ROI) de iniciativas de ciberseguridad.

2. Población objetivo y perfiles de respuesta

La encuesta se dirige a organizaciones públicas y privadas con exposición significativa a riesgos de ciberseguridad, incluyendo:

- Administración General del Estado, administraciones autonómicas y locales.
- Operadores esenciales e importantes según NIS2 (energía, salud, transporte, agua, finanzas, digital, etc.).
- Proveedores de servicios tecnológicos: cloud, SaaS, MSP, datacenters.

Perfiles recomendados de respuesta:

- CISO o Responsable de Seguridad de la Información.
- CIO, CTO o responsable TIC.
- Responsables de Riesgos, Cumplimiento o Auditoría Interna.
- Miembros de la alta dirección con responsabilidad sobre continuidad y riesgo.

3. Estructura de la encuesta

La encuesta se articula en bloques que reflejan los Trust Services Criteria (TSC) de SOC 2 y su alineamiento con ENS y NIS2:

1. Información general de la organización.
2. Gobernanza y entorno de control (CC1).
3. Información y comunicación (CC2).
4. Evaluación de riesgos (CC3).
5. Actividades de monitorización (CC4).
6. Actividades de control (CC5).
7. Controles de acceso lógico y físico (CC6).
8. Operaciones del sistema y gestión de vulnerabilidades (CC7).
9. Gestión de cambios (CC8).
10. Mitigación de riesgos (CC9).
11. Disponibilidad y continuidad.
12. Integridad del procesamiento.
13. Confidencialidad.
14. Privacidad y protección de datos.
15. Proveedores y cadena de suministro.
16. IA, automatización y riesgos emergentes.
17. Percepción, prioridades y recursos.
18. Comentarios abiertos.

Cada bloque incluye preguntas de opción múltiple con escalas de madurez y algunas preguntas abiertas para capturar matices narrativos.

4. Escalas de respuesta y lógica de puntuación

4.1 Tipo de escala

Las preguntas cerradas utilizan principalmente:

- Escalas ordinales de madurez (5 niveles) desde ausencia de práctica hasta enfoque sistemático y medido.
- Rangos porcentuales (0–20 %, 21–50 %, 51–80 %, 81–99 %, 100 %) para reflejar cobertura de controles.
- Frecuencias (nunca, ocasionalmente, anual, trimestral, mensual, continuo).

El tono de las descripciones combina precisión técnica con un toque irónico y literario, para invitar a la reflexión sin caer en la rigidez burocrática.

4.2 Asignación de puntuaciones por respuesta

Se recomienda traducir cada respuesta en un valor numérico normalizado, por ejemplo:

- Escala de madurez de 5 niveles: 0, 25, 50, 75, 100.
- Rangos porcentuales: 10, 35, 65, 90, 100 (para reflejar que el 100 % suele ser excepcional).
- Frecuencias: 0 (nunca), 25 (ocasional), 50 (anual), 75 (trimestral), 100 (mensual o continuo).

Las preguntas pueden agruparse por bloques para obtener subíndices temáticos y un Índice Global de Madurez (IGM), que será la media ponderada de los subíndices.

4.3 Ponderación de bloques

Se sugiere una ponderación de referencia, ajustable según sector:

- Gobernanza y entorno de control (CC1): 15 %.
- Evaluación de riesgos y monitorización (CC3, CC4): 20 %.
- Controles técnicos (CC5–CC8, accesos, vulnerabilidades): 30 %.
- Disponibilidad, integridad, confidencialidad, privacidad: 20 %.
- Proveedores, IA y riesgos emergentes: 10 %.
- Percepción y recursos: 5 %.

Esta ponderación refleja la importancia creciente otorgada a gobernanza, gestión de riesgos y resiliencia operacional en SOC 2 y NIS2.

5. Procedimiento de aplicación

5.1 Modalidad de recogida de datos

Se recomienda aplicar la encuesta mediante:

- Cuestionario en línea (formulario web o herramienta de encuestas) con control de acceso.
- Alternativamente, envío en formato editable (Markdown o equivalente) con consolidación posterior.

Debe garantizarse la confidencialidad de las respuestas y, en su caso, el anonimato cuando se usen para análisis comparativos sectoriales o nacionales.

5.2 Consentimiento y aviso de privacidad

Antes de iniciar la encuesta, se debe informar al participante sobre:

- Finalidad del tratamiento de datos (análisis de madurez, elaboración de informes agregados, benchmarking).
- Base jurídica aplicable (interés legítimo, misión de interés público, etc., según el promotor).
- Destinatarios de los resultados y periodo de conservación.
- Derechos de acceso, rectificación, supresión, etc., conforme al RGPD.

5.3 Tiempo estimado de cumplimentación

Para una respuesta reflexiva, se estima:

- 25–40 minutos para completar todas las secciones.
- Puede reducirse para organizaciones con marcos de ciberseguridad ya consolidados.

6. Construcción del Índice Global de Madurez (IGM)

6.1 Definición

El IGM es un indicador compuesto entre 0 y 100 que resume el grado de madurez de la organización en relación con los criterios SOC 2, ENS y NIS2, integrando gobernanza, control, resiliencia y cultura.

6.2 Pasos de cálculo

19. Asignar a cada respuesta una puntuación normalizada de 0–100.
20. Calcular la media (simple o ponderada) de las preguntas dentro de cada bloque para obtener subíndices.
21. Aplicar las ponderaciones definidas a cada bloque.
22. Calcular el IGM como suma de subíndices ponderados.

Ejemplo simplificado:

- IGM = 0,15·Gobernanza + 0,20·Riesgos/Monitorización + 0,30·Controles técnicos + 0,20·TSC (disponibilidad/confidencialidad/privacidad) + 0,10·Proveedores/IA + 0,05·Percepción/recursos.

6.3 Interpretación del IGM

Se proponen las siguientes bandas de interpretación:

- 0–24: Nivel inicial – Riesgo elevado, controles fragmentarios, dependencia de esfuerzos heroicos.
- 25–49: Nivel básico – Elementos clave presentes, pero sin enfoque integral ni métricas sólidas.
- 50–74: Nivel intermedio – Marco definido, controles razonables, aunque con lagunas y enfoque reactivo.
- 75–89: Nivel avanzado – Gestión sistemática, basada en riesgos y con enfoque de mejora continua.
- 90–100: Nivel líder – Integración plena con estrategia, resiliencia demostrada, cultura consolidada y visión de valor.

7. Marco de ROI de ciberseguridad

7.1 Enfoque general

La encuesta puede complementarse con un análisis de ROI de ciberseguridad que estime:

- Pérdidas anuales esperadas por incidentes (frecuencia x impacto) antes de inversiones significativas.
- Pérdidas anuales esperadas después de las inversiones (reducción de probabilidad o impacto).
- Costes de las inversiones en personas, procesos y tecnología.

7.2 Fórmula básica

Una aproximación simple al ROI de ciberseguridad:

- Beneficio anual esperado = Pérdida esperada antes – Pérdida esperada después.
- ROI (%) = (Beneficio anual esperado – Coste anual de la inversión) / Coste anual de la inversión · 100.

Este marco puede enriquecerse con modelos de cuantificación basados en FAIR u otras metodologías cuantitativas.

8. Sesgos, limitaciones y buenas prácticas

8.1 Sesgos comunes

- Sesgo de optimismo: tendencia a sobrestimar el nivel de madurez.
- Sesgo de cumplimiento: responder en función de “lo que debería ser” más que de “lo que es”.
- Sesgo de representatividad: respuestas centradas en una unidad organizativa concreta en lugar de la organización completa.

8.2 Medidas para mitigarlos

- Invitar a responder conjuntamente a representantes de seguridad, TI, negocio y cumplimiento.
- Contrastar la autoevaluación con evidencias (políticas, informes, métricas existentes).
- Recordar explícitamente que el objetivo es la mejora, no el juicio.

9. Uso de resultados y reporte

Los resultados de la encuesta permiten:

- Elaborar informes individuales por organización, con recomendaciones prioritarias.
- Generar informes agregados por sector, tamaño y tipo de organización.
- Alimentar ejercicios de planificación estratégica de ciberseguridad y programas de cumplimiento.

Se recomienda presentar los resultados con visualizaciones claras (gráficos radar, barras, mapas de calor) y un relato que conecte los hallazgos con los objetivos de negocio, la resiliencia y el cumplimiento regulatorio.